

מעבדת סייבר 2 – פרוייקט סיכום

המטרה: כתיבת קוד מאובטח, לפי העקרונות שנלמדו במעבדה.

השיטה: מימוש פונקציונליות והגנות בשרת ניהול משימות (טאסק) בשם BusyBee.

ניקוד: ניקוד יינתן על כתיבת קוד העומד בעקרונות התכנות המאובטח ועל פי מימוש ההגנות הצפויות ממתכנתים אשר כותבים קוד מאובטח.

הניקוד יהיה מחולק לסעיפים. כל סעיף יהיה בעל ניקוד בשווי מסויים. ביצוע הסעיף מזכה בניקוד.

חלק מהסעיפים מצויינים במסמך הנחיות זה וניתנים כדוגמא לצפוי מכם.

חלק מסעיפים מוסתרים במסמך זה וייחשפו רק בטופס הבדיקה הסופי. מצב זה מדמה את המציאות, בה לא נותנים לכם מראש רשימה של הדרוש מכם לתכנות מאובטח.

עבור הגנה שמישתם שאינה רשומה במפורד (סעיף נסתר) – תנו מיספור כרצונכם (המשיכו את המיספור הקיים).

חשיבה על הגנות וסעיפים שלא נכללים במסמך הבדיקה הסופי עשויים לזכות בנקודות בונוס.

פורמט הגשה

עליכם להגיש מסמך RTF (Rich Text Format) – אחת מהאופציות לשמירה ב-WORD.

המסמך יכול את החלקים הבאים:

• חלק 1: מימושים נדרשים (65 נקודות)

לכל סעיף יש להגיש קטעי קוד המדגימים את ביצוע הסעיף.

תשובת כל סעיף תתחיל בציון הסעיף – שם + אות. אם הוספתם סעיפים מעבר – תנו לסעיפים אותיות עוקבות לאות האחרונה של הסעיפים הרשומים מטה.

לפני כל קטע קוד יהיה שם הקובץ או שם החבילה הרלוונטיים.

קטע הקוד צריך להיות מינימליסטי (אידיאלית עד 5 שורות) – מותר לדלג על שורות לא רלוונטיות בעזרת 3 נקודות: ...

לשם הבהירות – אפשר להעתיק עם צבעים ורצוי להדגיש עם BOLD חלקים רלוונטיים במיוחד.

דוגמא:

[x-done]

controllers/TasksController.java

// **UUID** is defined at **java.util.UUID**

public record MarkDoneRequest(@NotNull **UUID** taskid) {}

@PostMapping("/done")

public ResponseEntity<MarkDoneResponse> markTaskDone

(@RequestBody MarkDoneRequest request)

• חלק 2: מימוש עצמי (30 נקודות)

בחלק זה עליכם לממש פיצ'ר בעצמכם.

מימוש הפיצ'ר צריך לעמוד בעקרונות של תכנות מאובטח.

צורת ההגשה דומה לחלק א', רק שבמקום שאני אגדיר את הסעיפים – אתם מגדירים את הסעיפים.

לכן - עליכם להגיש מסמך המכיל סעיפים, כשכל סעיף מתאר:

- משהו שהיה נחוץ לשם המימוש, אך לא קשור לתכנות מאובטח ("תוספת שדה 'צבע' ל-Task")
- פוטנציאל לחולשה + פתרון שמונע אותה ("מניעת חולשה אפשרית: מפתח הצפנה HARD CODED. מנעתי ע"י שימוש ב..."

כל סעיף יכול קטע קוד מתאים, או שורות קונפיגורציה מתאימות אם מדובר בקונפיגורציה.

רמז: מומלץ מאוד לפני שמממשים לשאול את CHATGPT מה החולשות הפוטנציאליות הצפויות במימוש הפיצ'ר

• **חלק 3: logging (5 נקודות)**

צרפו קובץ טקסט המכיל פירוט של כל קטעי הקוד המייצרים תוכן ללוג.

הנקודות ניתנות על כתיבת אירועים, חריגות, בעיות ללוג. שימו לב שכתיבה מוגזמת ללוג, של נתונים לא רלוונטיים, עלולה לגרור הורדה של נקודות. כמו כן – הימנעו מכתיבת נתונים שעלולים להיות רגישים (PII וכו').

שיטה לביצוע ב-INTELLIJ: מבצעים חיפוש על כל הקבצים (ctrl+shift+F) למילה LOGGER. בוחרים Open in Find Window, בחלונית שנפתחת בוחרים את כל השורות (ctrl+a), מקליקים כפתור ימני ובוחרים Export to Text File. מצרפים את הקובץ עצמו.

חלק 4: (10 נקודות) - בונוס

מימוש מנגנון CSRF על login, registration בעד 10 נקודות בונוס (ציון מירבי בפרויקט 110).

פירוט הניקוד

ובנוסף ניתנת נקודה על מימוש מנגנון מרכזי להמרת חריגות לסטטוס שגיאה (לפחות עבור חריגה אחת).

מימושים נדרשים – 65 נקודות

[5] `/login` – מאפשר אימות

מנגנוני בטיחות נדרשים:

#	ניקוד	מנגנון הגנה	הערות
א	1	סיסמאות נשמרות HASHED	
ב	1	אין סיסמאות גליות בקוד	
	3	(סעיפים מוסתרים)	

[5] `/done` – מאפשר לסמן משימה כגמורה

מנגנוני בטיחות נדרשים:

#	ניקוד	מנגנון הגנה	הערות
א	1	הגנה על הארגומנט taskid – וידוא שהוא UUID חוקי	יש להשתמש בטיפוס שמוודא תקינות
ב	1	החזרת סטטוס 404 אם task לא קיים	
ג	3	הרשאות: רק בעלים ואדמין יכולים לסגור טאסק	שימוש ב-SPEL. אופציונלית: אפשר שגם מי שב- responsibilityOf יוכל לסגור

[23] `/create` - מאפשר ליצור משימה

מנגנוני בטיחות נדרשים:

#	ניקוד	מנגנון הגנה	הערות
א	1	הגנה על הארגומנט name – שורה בודדת, ללא אפשרות לטאגים של HTML	יש להשתמש בטיפוס שמוודא תקינות
ב	1	הגנה על הארגומנט desc – מאפשר טקסט של מספר שורות, מאפשר הגדרת קישורים (<a>), צירוף תמונות (), ואפקטי טקסט bold, italic, underline	יש להשתמש בטיפוס שמוודא תקינות
ג	5	מניעת שימוש ב-desc ליצירת XSS	אופציה אחת היא ולידציה. כמו כן לגיטימי לשנות מ-HTML ל-Markdown או כל צורה אחרת שתמנע XSS. שימו לב שה-client משתמש ב-innerHtml בכדי להציג תוכן שדה זה ולכן אם שניתם קלט מ-HTML לפורמט אחר עליכם לבצע המרות כך שהפלט יהיה HTML. שימו לב: יש לאפשר מלוא הפונקציונליות שהוגדרה בסעיף

			הקודם! (קישורים, תמונות, ...)
ד	5	מניעת שימוש ב-desc ליצירת XSS – בדיקות תקינות	צרפו הרצת בדיקות בצד השרת על מנגנון מניעת ה-XSS שמראות שאתם מצד אחד חוסמים XSS ומצד שני עדיין מאפשרים את היכולות הנדרשות מ-desc (לינקים, תמונות וכו')
ה	1	הגנה על הארגומנט dueDate – תאריך חוקי בפורמט של LocalDate.	יש להשתמש בטיפוס שמוודא תקינות. יש לחסום תאריך ישן יותר מהתאריך של היום
ו	1	הגנה על הארגומנט dueTime – שעה חוקים בפורמט של LocalTime.	יש לחסום שילוב תאריך + שעה אשר יוצא בעבר
ז	1	הגנה על הארגומנט responsibilityOf	מכיל אך ורק שמות משתמש קיימים. שם משתמש מורכב מאות ואחריה אפס או יותר אותיות, ספרות ורווחים.
ח	1	החזרת סטטוס 409 אם שם ה-task קיים כבר	השוואה טקסטואלית פשוטה ע"פ שדה name
ט	2	בעלים נכון לטאסק	הבעלים של טאסק חדש היא המשתמשת הנוכחית
י	3	הרשאות ליציאת טאסק	ADMIN, CREATOR יכולים ליצור חופשי, TRIAL יכול ליצור רק אם אין לו טאסק "פתוח" (לא DONE)
יא	2	קוד נקי	למשל, אין catch בקוד, אלא טיפול בחריגות ע"י מנגנון מרכזי של SPRING

[22] [comment](#) / – מאפשר לייצר הערה (ניתנה לכם גרסה בנויה של חלק מהפונקציונליות, נדרש להוסיף תמיכה בהעלאת קבצים, לא מובטח שהמימוש הכתוב כרגע בקוד בטוח)

מנגנוני בטיחות נדרשים:

#	ניקוד	מנגנון הגנה	הערות
א	1	בדיקת מקום פנוי בדיסק	החזירו סטטוס 400 אם אין מספיק מקום פנוי בדיסק (ולא תשמרו את הקובץ)
ב-י	15	הגנות על העלאת קבצים	
יא-יט	6	(סעיפים מוסתרים)	

[10] [image](#) / – מאפשר להוריד תוכן של קובץ תמונה

מנגנוני בטיחות נדרשים:

#	ניקוד	מנגנון הגנה	הערות
א	2	הגנות יתירות Redundant defenses	
ב	1	כותרת (header) של content-type מכילה ערך נכון	
ג	3	בקונטרולר נפרד!!!	בסרטון שמנו את הפונקציונליות בקונטרולר של Task. יש להזיז לקונטרולר נפרד.
ד	1	הרשאות	רק ADMIN, בעלים ומי שברשימת responsibilityOf יכול לגשת לתמונה
	3	(סעיפים מוסתרים)	

מימושים עצמאיים – ביחרו אחד (30 נקודות):

מימוש HTTPS

תמיכה ב-HTTPS.

יש לכלול בסעיפים התייחסות ל- *certificate* + איבטוח שלו מפני חשיפה ב-GIT.

מימוש מנגנון EXPORT/IMPORT

מנגנון זה מאפשר למשתמשים לייצא טאסקים לקובץ ואז לתת אותם לחברים שיכולים לייבא את הטאסקים אליהם. כרגי עליכם לתמוך בייצוא ייבוא של על הטאסקים הפתוחים בלבד (בעתיד יהיה UI לבחור איזה טאסקים).
סוג המנגנון והקובץ לאיחסון הטאסקים המיוצאים *חייב* להיות JAVA SERIALIZATION.
שימו לב: למטרות לימודיות בחרתי בכוונה פורמט בעייתי מבחינת בטיחות, אשר יש להגן עליו בדרכים שונות.
יש לכלול בסעיפים הצעה לפורמט אלטרנטיבי שאינו סובל מסכנות אלה

מימוש העלאת תמונה בעזרת LINK

עליכם להוסיף לשרת תמיכה במנגנון המאפשר במקום להעלות תמונה – לתת לינק לתמונה (והשרת מוריד את התמונה ממיקום הלינק).